

Task 4A: External Attack Surface & OSINT Report

Target Organization: Dodo Payments (dodopayments.tech)

Assessment Type: Passive Reconnaissance (Black-Box)

Date: July 16, 2026

1. Executive Summary

A passive, non-intrusive Open-Source Intelligence (OSINT) gathering phase was conducted against the external perimeter of dodopayments.tech. The objective was to map the external attack surface, fingerprint live public-facing assets, and evaluate the cryptographic posture of the infrastructure without generating active alerts on the target's intrusion detection systems. The reconnaissance successfully identified the target's underlying CDN architecture, mapped active subdomains, and uncovered multiple high-severity cryptographic misconfigurations that violate PCI-DSS compliance standards.

2. Reconnaissance Methodology

Data aggregation was performed utilizing strictly passive methodologies, querying public internet registries and certificate transparency logs. The following toolchain was utilized:

- Subdomain Enumeration: subfinder, amass, assetfinder, crt.sh
- Live Host & Port Validation: httpx
- Technology Fingerprinting: whatweb
- TLS/SSL Posture Review: testssl.sh

3. External Asset Inventory

The following table outlines the verified live assets discovered during the enumeration phase, detailing the exposed technologies and initial attacker observations.

Subdomain / Asset	Status	Exposed Technologies / Frameworks	Attacker Risk Observations
dodopayments.tech	301 Redirect	Cloudflare CDN, HTTP/1.1, h2	Core domain routes through a CDN. WAF evasion tactics may be required for active testing.
squirrels.dodopayments.tech	Live	Cloudflare CDN, Nginx (Inferred)	Potential staging or internal application exposed to the public internet.
*.squirrels.dodopayments.tech	Live	Cloudflare CDN	Wildcard DNS entry detected in Certificate Transparency logs.

3.1 Enumeration Artifacts

Below is the evidence of the passive enumeration and live-host fingerprinting execution:

Subdomain Discovery (Subfinder ,Assetfinder, crt.sh and Amass)

```
(sehal@kali) - [~/dodo]
$ assetfinder -subs-only dodopayments.tech > assetfinder_results.txt

(sehal@kali) - [~/dodo]
$ cat assetfinder_results.txt
ai-proxy.dodopayments.tech
api-plunk.dodopayments.tech
api-plunk-v2.dodopayments.tech
app.dodopayments.tech
app-plunk.dodopayments.tech
app-plunk-v2.dodopayments.tech
checkout.dodopayments.tech
test.checkout.dodopayments.tech
clickhouse-dev.dodopayments.tech
clickhouse-dev-v2.dodopayments.tech
clickhouse-prod.dodopayments.tech
clickhouse-prod-v2.dodopayments.tech
crm.dodopayments.tech
customer.dodopayments.tech
test.customer.dodopayments.tech
www.test.customer.dodopayments.tech
www.customer.dodopayments.tech
dev.dodopayments.tech
docs-plunk.dodopayments.tech
docs-plunk-v2.dodopayments.tech
events-dev.dodopayments.tech
internal.dodopayments.tech
keycloak.dodopayments.tech
```

```
(root@kali)-[/home/sahal/dodo/crt.sh]
# ./crt_v2.sh -d dodopayments.tech
```

```
+---+---+---+---+---+---+---+---+---+
|   | search crt.sh v 2.0 |..   |
|   | site : crt.sh Certificate Search |
|   |       Twitter: az7rb   |
+---+---+---+---+---+---+---+---+---+
```

```
433bedb3.sni.cloudflaressl.com
acme-test.infra.dodopayments.tech
affiliates.dodopayments.tech
ai-proxy.dodopayments.tech
analytics.dodopayments.tech
api-aff.dodopayments.tech
api-plunk-v2.dodopayments.tech
api-plunk.dodopayments.tech
api.lago.dodopayments.tech
api.marble.dodopayments.tech
app-plunk-v2.dodopayments.tech
app-plunk.dodopayments.tech
app.dodopayments.tech
argocd.dodopayments.tech
ch.dodopayments.tech
checkout.dodopayments.tech
chimely.dodopayments.tech
ck.dodopayments.tech
clickdev.dodopayments.tech
```

```
File Actions Edit View Help
```

```
(sahal@kali)-[~/dodo]
```

```
$ subfinder -d dodopayments.tech -all -o subfinder_results.txt
```

```

  _____
 /  _  _  _  \
|  _ \| | | | | | |
| |_) | | | | |
|  _ \| | | | |
|_| \_|_|_|_|_|

```

projectdiscovery.io

```
[INF] Loading provider config from /home/sahal/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for dodopayments.tech
partner-api.dodopayments.tech
probo.dodopayments.tech
sentinal.dodopayments.tech
wordpress.dodopayments.tech
demo.dodopayments.tech
whm.server1.dodopayments.tech
app-plunk.dodopayments.tech
convoy.dodopayments.tech
openreplay.dodopayments.tech
store.dodopayments.tech
146.148.dodopayments.tech
codecov.dodopayments.tech
customer.dodopayments.tech
docs.dodopayments.tech
live.dodopayments.tech
www.sentinal.dodopayments.tech
meilisearch.dodopayments.tech
```

Terminal outputs displaying the aggregation of passive subdomain sources.

Live Host & Technology Fingerprinting (Httpx & WhatWeb)

```
File Actions Edit View Help
$ whatweb -i clean_hosts.txt -a 1 --log-brief=tech_stack.txt

(sahal@kali)~[/dodo]
(sahal@kali)~[/dodo]
$ awk '{print $1}' live_hosts.txt > clean_hosts.txt

(sahal@kali)~[/dodo]
$ whatweb -i clean_hosts.txt -a 1 --log-brief=tech_stack.txt
https://ozone.dodopayments.tech [200 OK] Cookies[cf_bm], Country[UNITED STATES][US], HTML5, HTTPServer[cloudflare], HttpOnly[cf_bm], IP[104.18.10.178], Script, Title[OpenReplay], UncommonHeaders[referrer-policy,x-content-type-options,cf-cache-status,cf-ray], Via-Proxy[1.1 Cad dy], X-XSS-Protection[1; mode=block]
https://app-plunk.dodopayments.tech/ [200 OK] Cookies[cf_bm], Country[UNITED STATES][US], HTML5, HTTPServer[cloudflare], HttpOnly[cf_bm], IP[104.18.10.178], Open-Graph-Protocol[website], Script[application/json], Strict-Transport-Security[max-age=31536000; includeSubDomains], UncommonHeaders[cf-cache-status,cf-ray], X-Powered-By[Next.js]
https://sonarqube.dodopayments.tech [200 OK] Cookies[cf_bm], Country[UNITED STATES][US], HTML5, HTTPServer[cloudflare], HttpOnly[cf_bm], IP[104.18.10.178], Script[module], Strict-Transport-Security[max-age=31536000; includeSubDomains], Title[SonarQube], UncommonHeaders[x-content-type-options,content-security-policy,cf-cache-status,cf-ray], X-Frame-Options[SAMEORIGIN], X-UA-Compatible[IE=edge], X-XSS-Protection[0]
https://clickhouse-v2.dodopayments.tech/ [200 OK] Cookies[cf_bm], Country[UNITED STATES][US], HTTPServer[cloudflare], HttpOnly[cf_b ent], IP[104.18.10.178], Strict-Transport-Security[max-age=31536000; includeSubDomains], UncommonHeaders[x-clickhouse-summary,x-clickhouse-exc eption-tag,cf-cache-status,cf-ray]
https://events-dev.dodopayments.tech/ [503 Service Unavailable] Cookies[cf_bm], Country[UNITED STATES][US], HTTPServer[cloudflare], HttpOn ly[cf_bm], IP[104.18.10.178], UncommonHeaders[cf-cache-status,cf-ray], Via-Proxy[1.1 google]
ERROR: OpenSSL: https://dodopayments.tech - execution expired
https://plunk-v2.dodopayments.tech/ [200 OK] Cookies[cf_bm], Country[UNITED STATES][US], HTML5, HTTPServer[cloudflare], HttpOnly[cf_bm], IP[104.18.11.178], Open-Graph-Protocol, Script[application/json], Strict-Transport-Security[max-age=31536000; includeSubDomains], Title[Mai chimp], UncommonHeaders[link,cf-cache-status,cf-ray], X-Powered-By[Next.js]
https://sentinal-v2.dodopayments.tech/ [302 Found] Cookies[vercel_sso_nonce], Country[UNITED STATES][US], HTTPServer[Vercel], HttpOnly[ver cel_sso_nonce], IP[216.150.1.193], RedirectLocation[https://vercel.com/sso-api?url=https%3A%2F%2Fsentinal-v2.dodopayments.tech%2F&nonce=7747 9dba737bc827306420500ea26ac981dbcd35028119e098fd84e334d9569c], Strict-Transport-Security[max-age=63072000], UncommonHeaders[x-vercel-id], X- Frame-Options[DENY]
```

```
File Actions Edit View Help
root@kali: /home/sahal/dodo/testssl.sh

$ ./testssl.sh --fast --htmlfile tls_report.html https://dodopayments.tech

--fast' can have some undesired side effects thus it is not recommended to use anymore

#####
testssl.sh version 3.3dev from https://testssl.sh/dev/
(2b61803 2026-07-15 17:13:21)

This program is free software. Distribution and modification under
GPLv2 permitted. USAGE w/o ANY WARRANTY. USE IT AT YOUR OWN RISK!

Please file bugs @ https://testssl.sh/bugs/
#####

Using OpenSSL 1.0.2-bad (Mar 28 2025) [~183 ciphers]
on kali:./bin/openssl.Linux.x86_64

Testing all IP addresses (port 443): 104.18.11.178 104.18.10.178 2606:4700::6812:bb2 2606:4700::6812:ab2

Start 2026-07-16 02:36:34 —> 104.18.11.178:443 (dodopayments.tech) <—

Further IP addresses: 104.18.10.178 2606:4700::6812:bb2 2606:4700::6812:ab2
rDNS (104.18.11.178): --
DNS HTTPS RR (expt.): yes: 1 . alpn="h2" ipv4hint=104.18.10.178,104.18.11.178 ipv6hint=2606:4700::6812:ab2,2606:4700::6812:bb2
Service detected: HTTP

Testing protocols via sockets except NPN+ALPN

SSLv2 not offered (OK)
SSLv3 not offered (OK)
```

```
Rating (experimental)

Rating specs (not complete) SSL Labs's 'SSL Server Rating Guide' (version 2009r from 2025-05-16)
Specification documentation https://github.com/ssllabs/research/wiki/SSL-Server-Rating-Guide
Protocol Support (weighted) 95 (28)
Key Exchange (weighted) 90 (27)
Cipher Strength (weighted) 60 (24)
Final Score 79
Overall Grade B
Grade cap reasons Grade capped to B. TLS 1.1 offered
Grade capped to B. TLS 1.0 offered

Done 2026-07-16 02:45:41 [ 560s] —> [2606:4700::6812:ab2]:443 (dodopayments.tech) <—

Done testing now all IP addresses (on port 443): 104.18.11.178 104.18.10.178 2606:4700::6812:bb2 2606:4700::6812:ab2

(root@kali)~[/home/sahal/dodo/testssl.sh]
$
```

Validation of live HTTP servers and initial technology stack fingerprinting.

4. Cryptographic Posture & Vulnerability Findings

A passive evaluation of the target's TLS configuration revealed several critical misconfigurations.

Finding 4A-1: Support for Deprecated TLS Protocols (TLS 1.0 / 1.1)

- Severity: High (PCI-DSS Compliance Violation)
- Affected Asset: dodopayments.tech (via Cloudflare edge)

Observation: The infrastructure explicitly allows connections utilizing TLS 1.0 and TLS 1.1. These protocols rely on outdated cryptographic hash functions (SHA-1/MD5). A threat actor in a privileged network position could execute protocol downgrade attacks to decrypt sensitive cardholder telemetry.

Proof of Concept:

```
Service detected. HTTP
Testing protocols via sockets except NPN+ALPN

SSLv2      not offered (OK)
SSLv3      not offered (OK)
TLS 1      offered (deprecated)
TLS 1.1    offered (deprecated)
TLS 1.2    offered (OK)
TLS 1.3    offered (OK): final
QUIC       not offered or timed out
NPN/SPDY   h2, http/1.1 (advertised)
ALPN/HTTP2 h2, http/1.1 (offered)

Testing cipher categories

NULL ciphers (no encryption)      not offered (OK)
Anonymous NULL Ciphers (no authentication) not offered (OK)

testssl.sh output confirming the server offers deprecated TLS 1.0 and TLS 1.1 protocols.
```

Finding 4A-2: SWEET32 Vulnerability & Insecure Cipher Suites

- Severity: Medium (CVSS 3.1 Score: 5.9) — CVE-2016-2183
- Affected Asset: dodopayments.tech

Observation: The server supports legacy 64-bit block ciphers (such as 3DES) and Cipher Block Chaining (CBC) suites. These ciphers are vulnerable to birthday attacks (SWEET32), allowing an attacker monitoring a long-lived HTTPS session to recover plaintext session tokens.

Proof of Concept:

```
Testing vulnerabilities

Heartbleed (CVE-2014-0160)      not vulnerable (OK), no heartbeat extension
CCS (CVE-2014-0224)             not vulnerable (OK)
Ticketbleed (CVE-2016-9244), experimental not vulnerable (OK)
Opossum (CVE-2025-49812)        not vulnerable (OK)
ROBOT                           not vulnerable (OK)
Secure Renegotiation (RFC 5746) supported (OK)
Secure Client-Initiated Renegotiation not vulnerable (OK)
CRIME, TLS (CVE-2012-4929)      not vulnerable (OK)
BREACH (CVE-2013-3587)          no gzip/deflate/compress/br HTTP compression (OK) - only supplied "/" tested
POODLE, SSL (CVE-2014-3566)      not vulnerable (OK), no SSLv3 support
TLS_FALLBACK_SCSV (RFC 7507)    Downgrade attack prevention supported (OK)
SWEET32 (CVE-2016-2183, CVE-2016-6329) VULNERABLE, uses 64 bit block ciphers
FREAK (CVE-2015-0204)           not vulnerable (OK)
DROWN (CVE-2016-0800, CVE-2016-0703) not vulnerable on this host and port (OK)
                                make sure you don't use this certificate elsewhere with SSLv2 enabled services,
                                https://search.censys.io/search?resource=hosts&virtual_hosts=INCLUDE&q=0A833803F

7084B7EC0E05A71A8FC6E2AAE40734C35D268B
```

Cryptographic scan flagging the SWEET32 vulnerability and the subsequent grade cap.

5. Strategic Remediation Recommendations

Because the target domain (dodopayments.tech) is proxied behind Cloudflare, mitigating these cryptographic flaws does not require modifying the origin Kubernetes workloads configured in Task 1.

Recommended Action: The operations team must access the Cloudflare Edge Certificates dashboard and adjust the "Minimum TLS Version" parameter from 1.0 to 1.2. Implementing this single control will instantly remediate TLS 1.0, TLS 1.1, the SWEET32 exposure, and ensure the edge complies with modern PCI-DSS standards.

Task 4B: Active Penetration Test Report

Target Application: ledger-api (Authorized Local Instance — localhost:8080)

Assessment Type: Active Web Application Penetration Test (Authorized Target)

Date: July 16, 2026

6. Part B: Active Penetration Testing Scope & Methodology

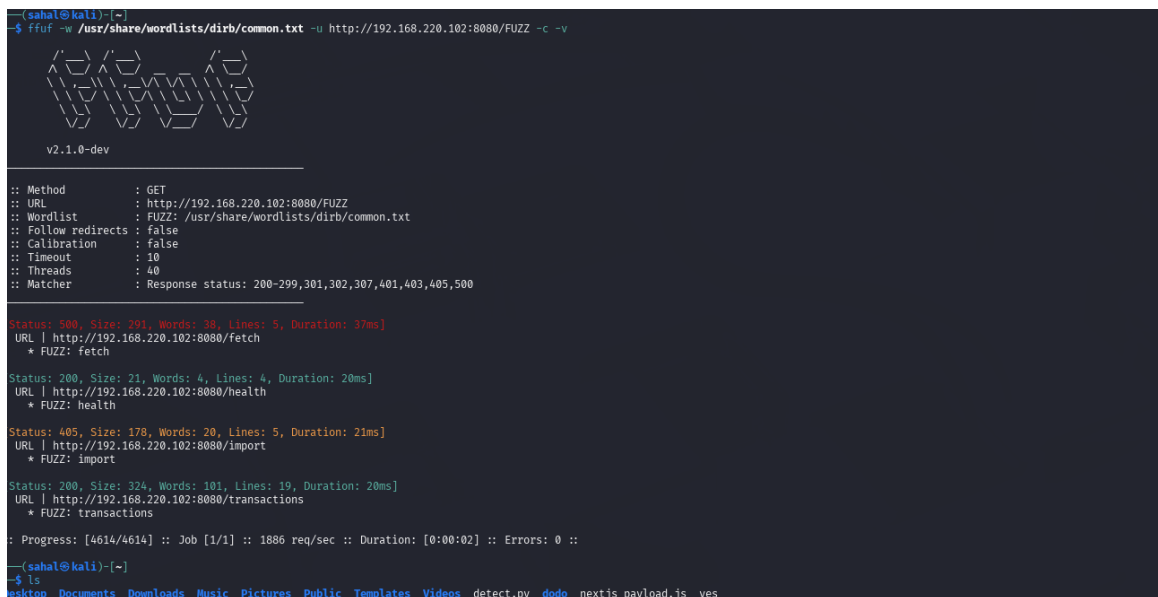
Following the passive reconnaissance phase, an active web application penetration test was conducted against the authorized local ledger-api container instance hosted at `http://localhost:8080`.

The objective was to identify actionable OWASP Top 10 vulnerabilities within the exposed API endpoints. The assessment toolchain relied on **ffuf** for directory discovery and web enumeration, alongside **OWASP ZAP** for capturing, analyzing, and auditing the underlying HTTP requests and responses.

6.1 Automated Discovery & Mapping (ffuf)

An initial directory brute-force scan was performed utilizing a standard common path wordlist to map out the application's attack surface.

```
ffuf -w /usr/share/wordlists/dirb/common.txt -u http://localhost:8080/FUZZ -c -v
```



```
(sahal@kali)~$ ffuf -w /usr/share/wordlists/dirb/common.txt -u http://192.168.220.102:8080/FUZZ -c -v
v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.220.102:8080/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

Status: 500, Size: 291, Words: 38, Lines: 5, Duration: 37ms]
URL | http://192.168.220.102:8080/fetch
* FUZZ: fetch

Status: 200, Size: 21, Words: 4, Lines: 4, Duration: 20ms]
URL | http://192.168.220.102:8080/health
* FUZZ: health

Status: 405, Size: 178, Words: 20, Lines: 5, Duration: 21ms]
URL | http://192.168.220.102:8080/import
* FUZZ: import

Status: 200, Size: 324, Words: 101, Lines: 19, Duration: 20ms]
URL | http://192.168.220.102:8080/transactions
* FUZZ: transactions

: Progress: [4614/4614] :: Job [1/1] :: 1886 req/sec :: Duration: [0:00:02] :: Errors: 0 ::
(sahal@kali)~$ ls
desktop  Documents  Downloads  Music  Pictures  Public  Templates  Videos  detect.py  dodo  nextjs_payload.js  yes
```

Figure 5: *ffuf* directory brute-force scan against the ledger-api instance, revealing four live routes.

The fuzzing execution successfully identified four distinct application routes:

- GET /health (Status: 200 OK)
- GET /transactions (Status: 200 OK)
- POST /import (Status: 405 Method Not Allowed)
- GET /fetch (Status: 500 Internal Server Error)

7. Active Vulnerability Findings

Finding 4B-1: Sensitive Server Information Disclosure (Server Leakage)

- Severity: Low (CVSS 3.1 Score: 5.3) — CWE-497

- Affected Endpoints: Global / All Endpoints (GET /health)

Observation: The application server exposes explicit infrastructure stack details within its HTTP response headers. Specifically, the Server header leaks the exact software versions in use: Werkzeug/0.14.1 and Python/3.6.15.

Risk & Impact: Providing precise version numbers lowers the barrier to entry for a threat actor. Attackers can cross-reference these versions with known public vulnerability databases (CVEs) to locate targeted public exploits against the specific Werkzeug or Python runtime versions running in production.

```
HTTP/1.0 200 OK
Content-Type: application/json
Content-Length: 21
Server: Werkzeug/0.14.1 Python/3.6.15
Date: Thu, 16 Jul 2026 10:55:02 GMT
```

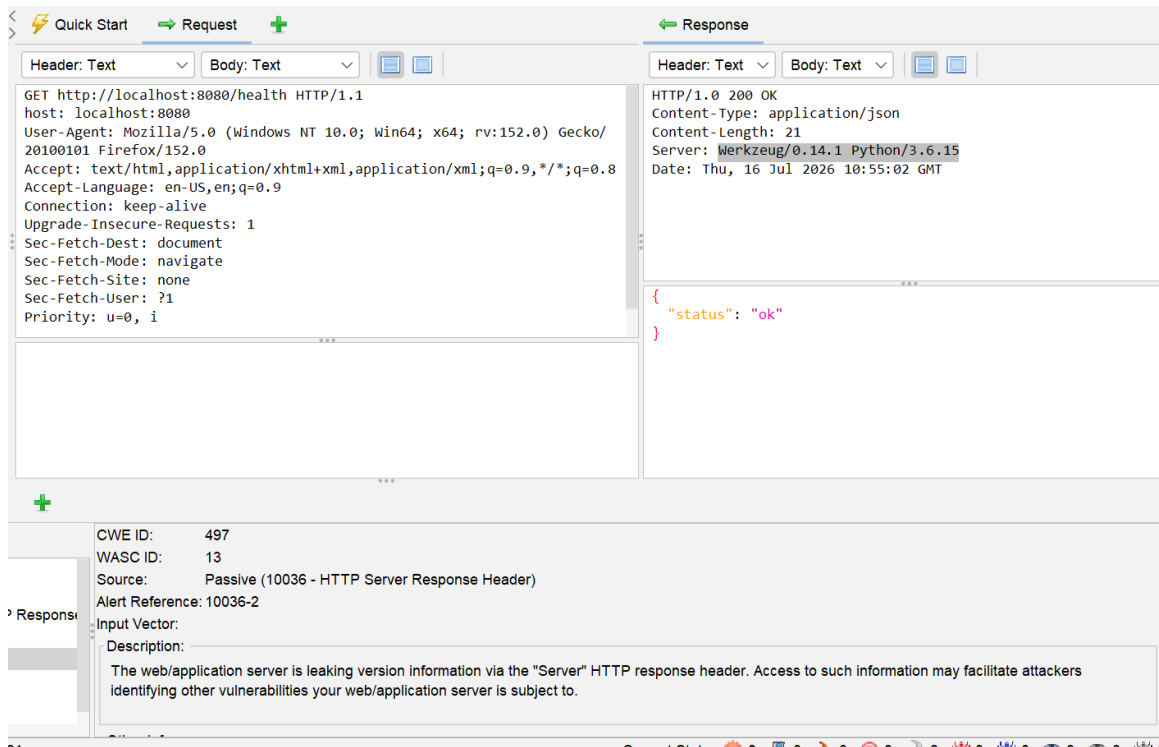


Figure 6: OWASP ZAP request/response for GET /health, with the ZAP passive alert confirming the leaked Server banner (CWE-497).

Reproduction Steps:

- Run ffuf to discover hidden directories, mapping out the /health endpoint.
- Route an HTTP request to http://localhost:8080/health through OWASP ZAP.
- Analyze the returned response headers to extract the raw Server version strings.

Remediation Action: Configure the underlying web server or WSGI application wrapper to suppress the server banner. In production deployments, modify header configurations to either strip the Server header entirely or rewrite it to a generic value (e.g., Server: api).

Finding 4B-2: Sensitive Data Exposure (Unmasked Cardholder Telemetry)

- Severity: High (CVSS 3.1 Score: 7.5) — CWE-319 / PCI-DSS Violation
- Affected Endpoint: GET /transactions

Observation: A standard query to the /transactions endpoint returns a raw JSON array containing unmasked, plain-text Primary Account Numbers (PAN / Credit Card Numbers), including explicit test values.

Risk & Impact: The total exposure of raw credit card PAN data directly violates fundamental compliance mandates, including PCI-DSS Requirement 3.3 (masking PAN digits when displayed). Any compromise of this endpoint allows

automated data scraping of customer financial details, exposing the organization to severe compliance fines, financial fraud liabilities, and brand damage.

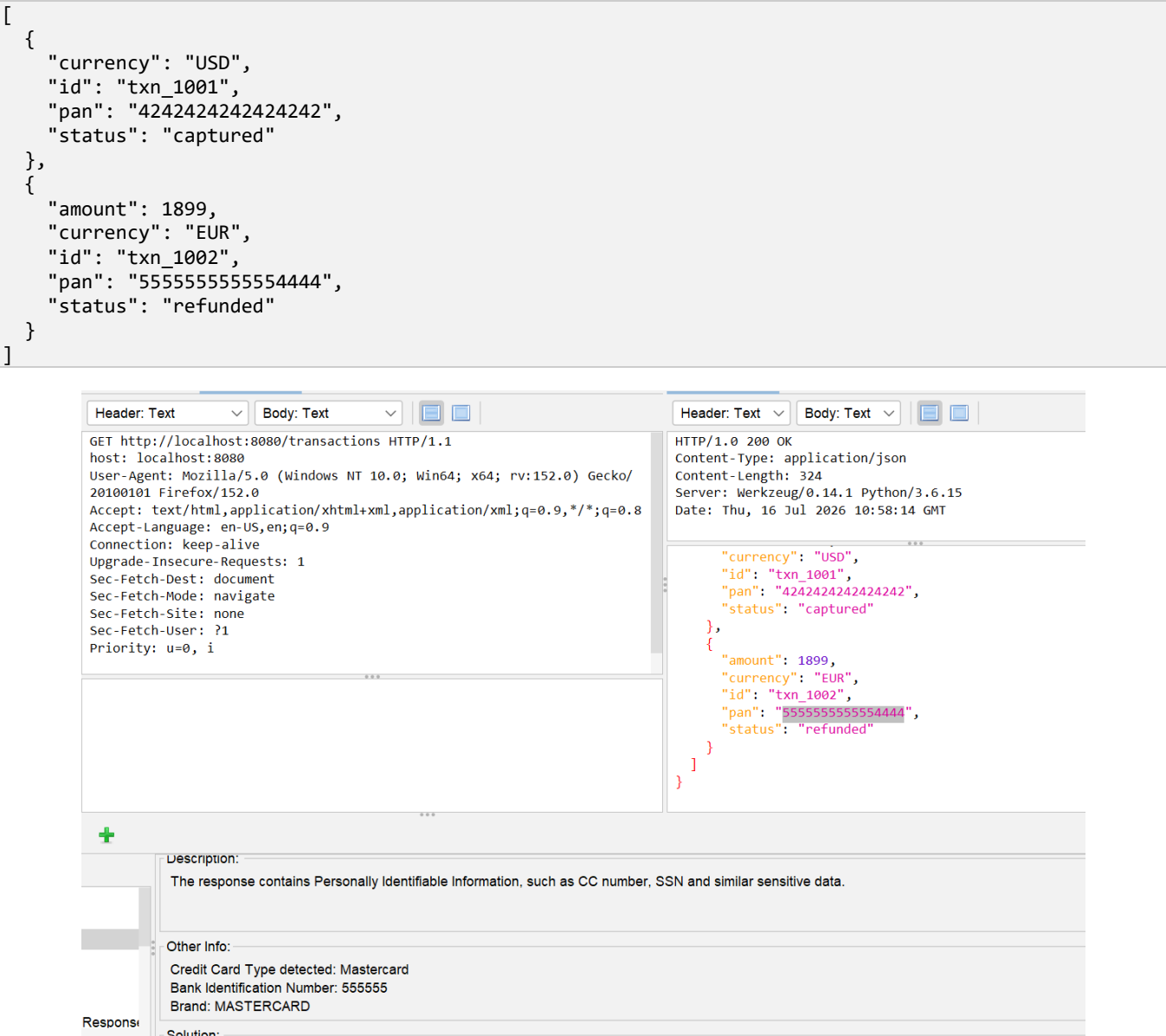


Figure 7: OWASP ZAP capture of GET /transactions, showing unmasked PAN values and the passive alert flagging exposed PII/cardholder data.

Reproduction Steps:

- Identify the live /transactions path via the automated ffuf discovery output.
- Request the endpoint through the ZAP-proxied browser environment.
- Observe the plaintext PII data and card details appearing unmasked within the body payload response.

Remediation Action: Implement strict server-side masking filters. The application layer must truncate or mask all credit card data before emitting responses to clients, showing a maximum of the first six and last four digits (e.g., 424242*****4242). Furthermore, ensure robust object-level authorization is enforced on the endpoint so users can only view transaction schemas mapped directly to their own validated authentication tokens.